metricstream

The Modern GRC Leader's Guide to AI-First Risk and Compliance



This document is not licensed for distribution.
Unauthorized reproduction, distribution, or disclosure of any part of this material is strictly prohibited. No part of this document may be copied or distributed without explicit approval from MetricStream.

© 2026 Copyright MetricStream. All Rights Reserved.

Contents

04 Introduction

06 The New Risk Reality: Why AI Is Transforming GRC

07 Understanding AI in the Context of GRC

08 Use Cases: How AI Is Changing GRC Operations

12 The AI-First GRC Operating Model

13 Maturity Model: Where Leaders are Today on Their AI Journey

14 Implementation Roadmap

15 Risks, Challenges, and Pitfalls

16 Key Metrics and KPIs for AI-First GRC

17 Case Studies & Real-World Success Stories

18 What Good Looks Like: The Future of AI in GRC

19 Conclusion

20 About MetricStream

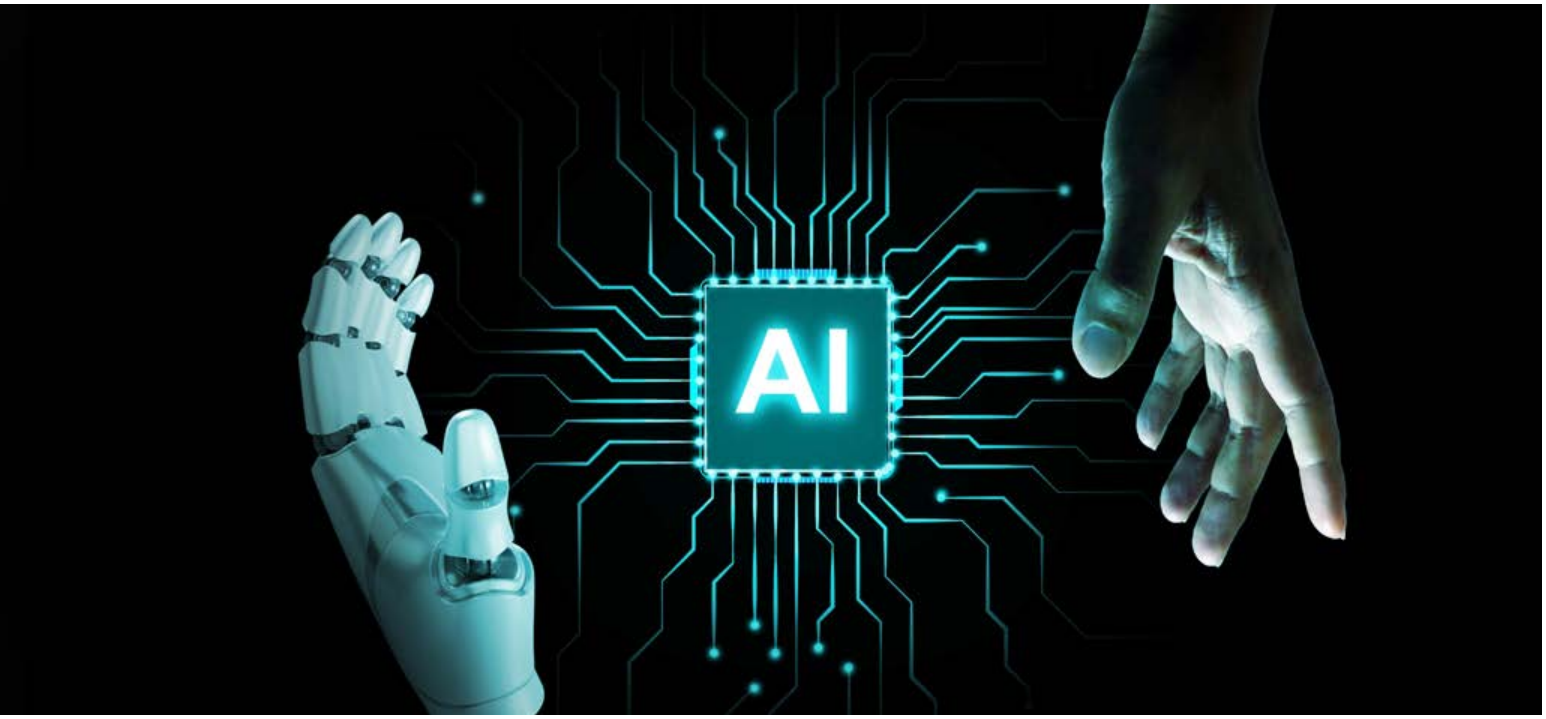
Introduction

Today's enterprises operate in a fraught risk environment. There are marked increases in cyber threats, geopolitical tensions, and the use of new technologies to mount sophisticated attacks. Regulators worldwide are implementing new frameworks and standards to protect enterprises and the public from emerging risks. The EU implemented DORA and the NIS2 Directive, which require organizations to implement stringent cyber and operational resilience measures. And the EU AI Act introduced the world's first comprehensive regulation on the use of AI. Effective compliance demands continuous, demonstrable control effectiveness and board level accountability.

Traditional, manual governance, risk, and compliance (GRC) practices can no longer keep pace with this risk and regulatory environment. It's too fast, complex, and interconnected. Artificial intelligence is critical for reshaping how organizations monitor risks, meet regulatory requirements, and make informed, swift decisions.

According to MetricStream's 2025 GRC Practitioner Survey Report, 43 percent of GRC professionals are actively evaluating AI solutions to understand how they can work for their organizations and the value they deliver. 35 percent are creating future roadmaps even before piloting specific use cases. And 14 percent have already integrated AI into their GRC frameworks.

This eBook explores how AI is transforming GRC from a reactive, compliance-driven function into a proactive, intelligence-led capability that drives strategic decision-making. It showcases where AI delivers the most value, and highlights what leaders must do to turn AI from a technical tool into a core strategic capability for resilience, performance, and trust.



Key takeaways for leaders:

- Regulatory expectations are increasing and evolving continuously, making manual, siloed GRC models ineffective.
- Regulatory expectations (NIS2, DORA, state and local mandates, EU AI Act) are focused on continuous monitoring, explainability, and robust AI model governance.
- AI GRC capabilities can drive the shift from reactive, sample-based oversight to continuous, intelligence-driven assurance across all three lines of defense.
- AI must be treated as a comprehensive strategic capability powered by outcomes and not as bolted-on technology to be effective.
- Successful adoption requires strong data foundations, prioritized use cases, governance for models and data, change management, workforce upskilling, and clear evaluation metrics.
- AI can enhance human expertise with scale, pattern detection, and speed. People must provide context, ethical oversight, and final decisions.



The New Risk Reality: How AI Is Transforming GRC

The risk landscape has fundamentally changed. According to the CrowdStrike 2026 Global Threat Report, the average cyberattack breakout time from initial access to lateral movement is now just 29 minutes, with AI-enabled attacks increasing by 89% year-over-year. Add geopolitical tensions and market volatility, third-party and AI-driven risks to the mix, and you have a corporate environment defined by constant disruption. At the same time, emerging regulatory frameworks such as DORA, the NIS2 Directive, and the EU AI Act are emphasizing board-level accountability for cyber and technology risks. They require ongoing, verifiable demonstration of control design and operating effectiveness. Most mandates include third-party vendors and suppliers, adding to compliance complexity and requiring continuous oversight and governance.

Traditional GRC programs with periodic risk assessments, manual control testing, and static reporting simply cannot keep pace with this complex, constantly evolving risk landscape. GRC teams must be able to correlate signals across IT, operational technology, cloud, third parties, and business processes at scale. They must be able to identify emerging risks, predict failures, and intervene early on. Organizations need continuous monitoring mechanisms and near-real-time reporting, which is only possible with AI-powered automation. AI GRC processes can continuously map regulatory requirements to controls, monitor evidence flows, and flag gaps or deteriorating control health long before an inspection or incident, directly supporting demonstrable compliance.



Understanding AI in the Context of GRC

AI in the context of GRC refers to a comprehensive set of capabilities that must be applied strategically to enhance insight, speed, and effectiveness of GRC practices. These include:



Machine learning and predictive analytics that can detect patterns and anomalies, forecast loss events, and identify risk indicators across datasets.



Generative AI, which inherently encompasses advanced natural language processing (NLP) for interpreting regulations, policies, audit reports, and contracts at scale, and summarizing obligations, controls, and issues for easy reference and quick decision-making.



AI agents that can automate and orchestrate workflows, trigger tasks, and interact with users to autonomously execute repeatable GRC activities.

AI GRC can deliver value across the three lines of defense. The first line helps ensure real-time monitoring and control validation. It embeds risk alerts in operational workflows to improve detection and identification. For the second line, it delivers continuous risk assessments and compliance monitoring and ensures policy oversight. And for the third line, it conducts in-depth root-cause analysis and provides insights, enabling risk-based audit planning and continuous auditing.

There have been persistent concerns that AI will replace human expertise and jobs. But AI is just a tool that can enhance speed, scale, simplify complexity, and augment decision-making. It can automate routine tasks so teams can focus on critical thinking and strategy, and it must always operate with a human-in-the-loop, ensuring oversight and governance. AI democratizes the power of cutting-edge data analytics by making it accessible to every organization, regardless of size or capital.

Use Cases: How AI Is Changing GRC Operations

Let's take a look at some of the key use cases of AI across GRC.

1. Governance

AI brings clarity and consistency to complex environments, helping organizations simplify and streamline governance efforts in the following ways:

- **Generates AI-driven executive narratives** that translate technical risk data, KRI breaches, and control results into clear, business-ready insights for senior leadership.
- **Supports intelligent policy management** by automating the reading of regulations, mapping them to internal policies, and identifying gaps and overlaps. AI models classify policies, detect conflicts, and suggest updates when external requirements change.
- **Establishes dynamic control frameworks** by linking regulatory obligations, risks, and controls across multiple frameworks, reducing duplication, simplifying the control library, and ensuring consistent compliance with evolving regulations.
- **Delivers comprehensive governance dashboards** that provide a concise view of risk intelligence across trends, scenario impacts, and leading indicators, enabling leaders to make faster, better-informed decisions on risk appetite, investments, and resilience trade-offs.



2. Risk Management

An AI-first GRC engine enables organizations to move from fragmented, periodic risk evaluations to continuous, intelligence-led risk management:

- **Provides automated executive insight** through an AI Chief Risk Officer Agent that extracts and summarizes critical risk information for senior leaders.
- **Continuously updates risk scores** by processing large volumes of operational, cybersecurity, financial, and third-party data as conditions change.
- **Predicts emerging risk events** using historical data and external signals to forecast issues such as payment fraud, system outages, or compliance breaches, allowing teams to take preventive action.
- **Performs scenario modeling and stress testing** using data-driven analysis to assess complex risk scenarios and estimate potential impact under varying assumptions.
- **Strengthens operational resilience** by detecting weak signals across incidents, near misses, and real-time operational data to uncover systemic vulnerabilities.
- **Recommends control effectiveness ratings** by analyzing control test results, self-assessments, and historical data, accelerating Risk and Control Self-Assessments (RCSAs).
- **Delivers AI-powered CRO monthly briefs** that consolidate:
  - Predictive analytics across leading and lagging KRIs
  - Dynamic threshold logic to identify anomalies and emerging risks
  - AI-generated executive summaries linking KRIs to control performance



3. Compliance

AI automates compliance operations to deliver faster, more accurate, and more scalable outcomes:

- **Enhances regulatory change management** by continuously tracking regulatory sources, classifying changes, and linking them to impacted entities, processes, and controls—significantly reducing manual tracking effort.
- **Automates evidence collection** by pulling tickets, configurations, and documentation directly from source systems into structured evidence packages aligned to control requirements.
- **Enables continuous control testing** by shifting compliance from periodic reviews to near real-time assurance through AI-driven monitoring and testing.
- **Refines and standardizes control narratives** to improve clarity, consistency, and audit readiness.
- **Automatically summarizes assessments** by highlighting gaps and recommending remediation actions.
- **Automates control testing activities** including execution, evidence collection, and result summarization.
- **Filters regulatory noise** by prioritizing relevant regulatory changes and accelerating compliance responses.
- **Provides AI-powered policy assistance** with plain-language, role-based answers to policy questions.
- **Detects policy contradictions and overlaps** to maintain consistency across the policy framework.
- **Drafts and updates policies automatically** based on regulatory changes, reducing manual effort.
- **Compares policy versions intelligently** and highlights changes to support audits and governance.
- **Recommends relevant frameworks, standards, and controls** to strengthen policy alignment and coverage.

4. Cyber Risk & Security

Modern cyber risk is sophisticated, fast-moving, and increasingly difficult to detect. AI is now foundational to managing this complexity effectively:

- **Improves threat detection** by continuously analyzing network traffic, endpoint behavior, user activity, and external threat intelligence to identify anomalies and attack patterns with higher signal accuracy.
- **Unifies cyber risk visibility** by consolidating assets, vulnerabilities, patch status, incidents, and test findings into a single, connected risk view through seamless integrations.
- **Enables attack path analysis and risk-based prioritization** by modelling relationships between assets, vulnerabilities, and identities to identify likely threat paths and prioritize remediation.
- **Accelerates and standardizes cyber risk assessments** through AI-driven surveys that flag out-of-expectation or high-risk responses for focused follow-up.
- **Reduces vendor assessment effort** by pre-filling responses using uploaded evidence such as policies, audits, and reports, improving response speed and completeness.
- **Supports continuous control monitoring** to ensure critical cyber controls remain effective over time, rather than relying on point-in-time assessments.

5. Audit

AI-first GRC systems transform audit from retrospective assurance to forward-looking, continuous insight:

- **Enables continuous internal auditing** by analyzing transaction-level data and control telemetry to surface exceptions as they occur, rather than only during scheduled audits.
- **Summarizes large evidence sets** and pre-populates narratives while linking findings directly to risks and controls.
- **Improves risk-based audit planning** using predictive analytics to rank entities, processes, and systems by emerging risk.
- **Delivers deeper root-cause analysis** by identifying patterns and trends across large volumes of audit data.
- **Automates workpaper creation and checklist completion** while summarizing supporting documentation.
- **Enhances audit content quality** through intelligent writing assistance, structuring, and quality checks.
- **Improves audit consistency and efficiency** by reducing fieldwork effort and accelerating audit cycles.
- **Allows auditors to focus on judgment and strategic insights** rather than manual documentation tasks.

The AI-First GRC Operating Model

An AI-first GRC operating model is built on continuous data flows, embedded automation, and a close partnership between risk, technology, and business teams. Key components include:

- A unified data fabric that integrates operational, security, financial, and external data.
- Intelligent workflow orchestration that automates assessments, testing, and responses, and also embeds controls and approvals into business processes.
- AI models built for detecting, predicting, and summarizing risk, compliance, and assurance use cases.
- An insight layer that delivers role-based, customized dashboards and co-pilots for better decision-making.

AI-first GRC solutions cannot operate effectively in isolation. Organizations must be able to integrate AI into existing GRC programs. Human expertise will remain critical, with people focusing on interpretation, oversight, and strategic guidance. Human and AI collaboration requires organizations to define roles and skills, and to focus on workforce upskilling, data literacy, model awareness, and scenario thinking. Governance strategies need to consider not just risks to the business but also risks arising from AI itself.



Maturity Model: Where Leaders are Today on Their AI Journey

Not all organizations are at the same level when it comes to their GRC programs, and can be mapped across a four-stage maturity spectrum:



Manual: Organizations at this level are still using spreadsheets and email workflows. Their GRC strategies are based on reactive compliance, periodic assessments, and minimal analytics or automation.



Automated: Organizations at this stage are using point tools for workflow, but still follow largely static strategies. They have basic rule-based monitoring and some integration capabilities, but limited AI capabilities.



Intelligent: These organizations are leveraging AI and predictive analytics across key GRC processes. They are using AI-assisted insights for risk-based prioritization and ensuring continuous monitoring



Autonomous: Companies at this level have moved on to the latest stage of AI evolution to implement agentic AI models under human oversight. These organizations have self-adjusting controls and real-time risk orchestration.

An enterprise's position on this maturity scale can be evaluated by mapping its processes and systems against the following criteria:

- Technology or extent of AI in use and its integration within workflows and systems
- Process or the level of continuous monitoring
- People or skills and data literacy within teams
- Governance or model oversight and policies.

Leaders can assess their current state through structured assessments that benchmark capabilities against peers and regulatory expectations.

Implementation Roadmap

Here is a practical roadmap for moving to an AI-first GRC strategy:

1. **Define objectives and outcomes**
   Identify and document long-term strategic goals such as faster issue detection, audit effort reduction, improved cyber resilience, or regulatory readiness. Break them down into smaller, measurable targets that can be periodically revisited to monitor progress.

2. **Build the data foundation**
   To be successful and deliver the intended results, AI models need to ingest a constant stream of high-quality data. List data sources, address quality issues, and establish secure, governed access patterns.

3. **Identify high-impact use cases**
   Prioritize cases that present evident pain points, where AI can demonstrably improve cost, speed, or risk. Choose problem cases where logs, documents, tickets, incidents, and control data already exist and can be connected.

4. **Prioritize risk areas for automation**
   Focus on high-stakes domains like cyber-risk monitoring, third-party risk management, and financial reporting, where improvements are immediately visible and defensible.

5. **Choose platforms and tools**
   Assess GRC and AI platforms against criteria like integration, explainability, security, and roadmap alignment. Opt for solutions that can be scaled to support a wide variety of use cases in the long run.

6. **Establish governance and model oversight**
   Define policies and committees for AI usage, model validation, monitoring, and incident handling, as well as aligning with evolving AI regulations.

7. **Train teams and redefine processes**
   Invest in ongoing upskilling and training programs for teams across risk, compliance, and audit functions. Redesign workflows to embed AI outputs, and adjust roles to emphasize interpretation and oversight.

8. **Measure impact and optimize**
   Consistently track KPIs such as cycle time reductions, coverage improvements, and incident outcomes. Feed the results and learnings back into the model for fine-tuning and improving the process over time.

Risks, Challenges, and Pitfalls

AI in the workplace is not without some risks. About 80 percent of corporate leaders are concerned about AI risks within governance programs, even though only a quarter of them have actually implemented AI GRC strategies.

Here are the top risks and challenges associated with AI in GRC programs

Model errors and hallucinations – 34 percent of leaders are concerned about AI hallucinations or erroneous information invented by an AI model, and for good reason. Generative AI is particularly prone to hallucinations that can mislead decision-making if not adequately monitored and validated. Organizations need robust testing, guardrails, and human oversight and review to address this risk.

Data quality and bias - An AI model is only as good as the data used to train it. If the core data is faulty or includes skewed patterns, the model can reproduce and sometimes intensify those patterns in decisions. This is why AI must always work with a human-in-the-loop. Human understanding of nuances and context is critical for monitoring and providing feedback to AI models.

Over-automation without oversight – AI can make day-to-day tasks easier, faster, and more accurate, making it easy to fall into the over-automation trap. This refers to automating a task beyond what is appropriate for its risk level or complexity, so the system does things by default without human oversight. As a result, people stop understanding the underlying process and can no longer step in effectively when something goes wrong. In GRC functions, over-automation leaves the organization susceptible to hidden control failures, model and rule drift, bias and hallucination, and regulatory risk.

Shadow AI usage– When corporate AI tools are slow or difficult to use, employees may turn to unauthorized tools to speed up and simplify their workloads. Recent research found that 80 percent of professionals, including 90 percent of security professionals, use unapproved AI tools in their jobs. This shadow AI infrastructure poses serious data security, privacy, and compliance risks.

Change resistance and skills gaps – AI in GRC represents a sea change from established legacy processes. Successful adoption requires clear communication of benefits, involvement of first-line users, and alignment with performance objectives. Comprehensive training and upskilling programs are essential for ensuring that the workforce is capable of working alongside AI models.

Increased regulatory expectations for transparency – As adoption increases, so does regulatory scrutiny. New AI standards like the EU AI Act are increasingly making explainability and audit-trails non-negotiable, with clear expectations around thorough documentation of AI models, decisions, disclosures, and controls.

Key Metrics and KPIs for AI-First GRC

AI implementation is quickly moving from experimental pilot projects to strategic transformations that drive business value. It is important to track and measure the benefits delivered by the AI GRC solution. Organizations must track key metrics to understand AI's impact on GRC processes:

- Better Efficiency - Reduction in time for control testing, evidence gathering, and audit preparation, faster decision turnaround times
- Better Risk Management and Resilience– Faster risk detection speed and response time, fewer business disruptions, better continuity of critical services, and effectiveness of scenario testing.
- Improved Compliance - Reduction in audit findings and compliance issues
- Improved Quality - Control effectiveness and coverage, reduction in repeat findings or material weaknesses, fewer late regulatory filings
- Demonstrable value - Benchmarking against peers and industry surveys helps calibrate ambition and demonstrate value to boards and regulators.

Mature organizations integrate these KPIs into regular performance dashboards for risk, compliance, audit, and business leadership.



Case Studies & Real-World Success Stories

Organizations across sectors have already started leveraging AI in GRC. MetricStream has helped many customers with our AI-first Connected GRC approach that leverages AI to automate control testing, evidence collection, and risk analytics. This ensures enterprise-wide risk visibility and eliminates manual processes, resulting in a significant reduction in cost and complexity of disconnected, siloed solutions.

Our customers witnessed a 30 percent reduction in GRC-related costs and an almost 60 percent reduction in manual control testing. They also benefited from shorter detection times and shorter time to address incidents. Our real-time board dashboards replaced quarterly reports and enhanced vendor-risk visibility through AI scoring models.

Organizations are also leveraging NLP for regulatory change intelligence, reducing the time to analyze new rules. They are also using ML-based anomaly detection to identify fraud or operational errors that traditional rules may miss.



What Good Looks Like: The Future of AI in GRC

Organizations across sectors are rapidly moving to AI-first GRC programs to keep pace with the disruptive risk and regulatory environment. Here's what the future of AI in GRC is likely to look like:

Agentic AI Models - Autonomous AI GRC solutions that feature self-updating risk registers, automated evidence collection, and agents that orchestrate end-to-end workflows under human oversight.

Real-Time, Self-Healing Controls – These detect misconfigurations or policy breaches and trigger automated remediation actions where appropriate

AI Copilots – These support risk owners, compliance officers, and auditors with contextual guidance

24×7 risk intelligence dashboards – Consolidated view into continuously refreshed views of exposures, trends, and emerging threats.

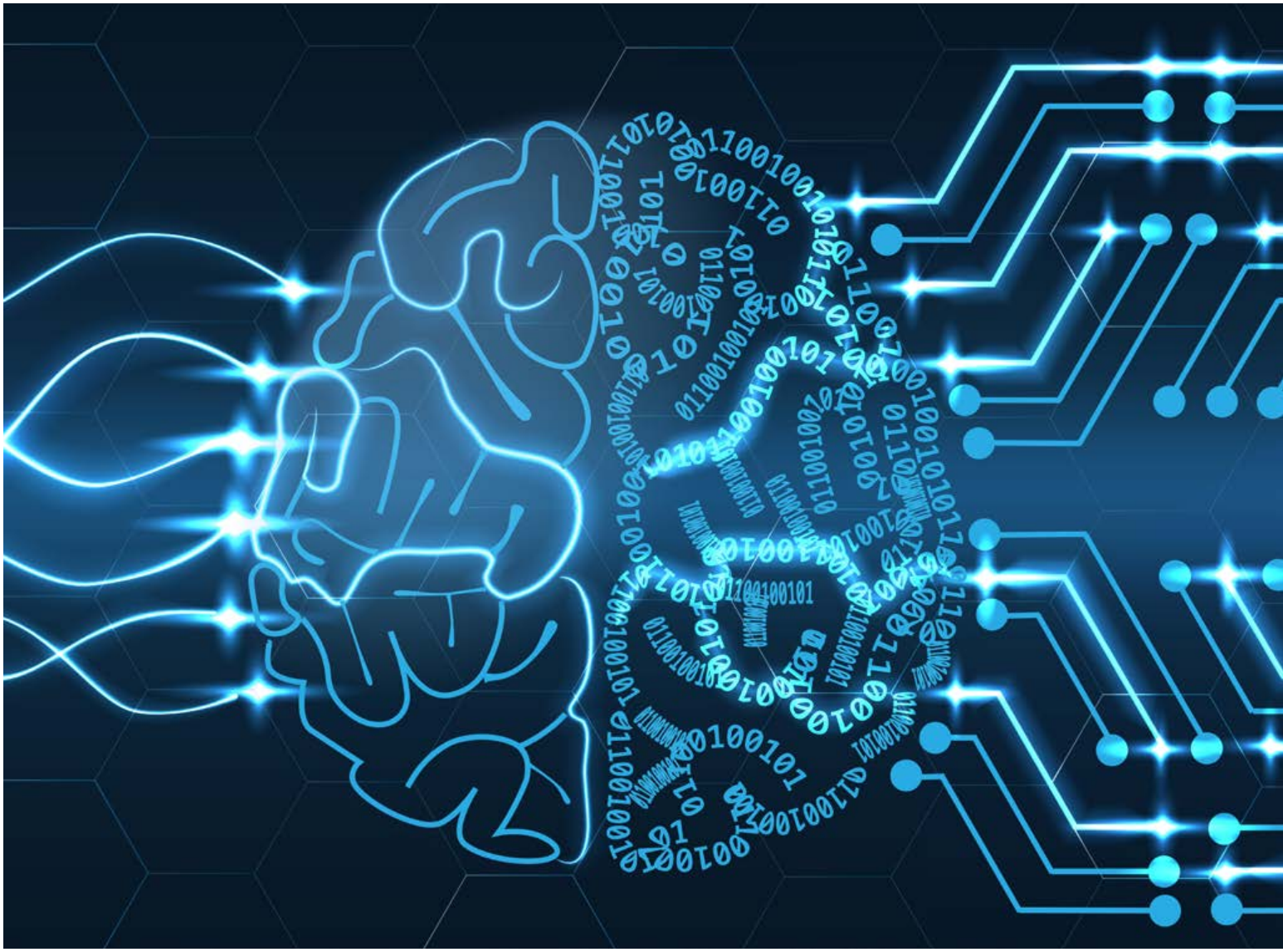
Workflows orchestrated by Gen AI agents - Generative AI agents will increasingly operate as front-line assistants to draft policies, prepare board reports, simulate scenarios, and respond to internal queries. They will also ensure dedicated governance.

Interested to see AI-Powered GRC in Action.
Take a Demo of MetricStream's GRC Solution
Click Here



Conclusion

AI is redefining what effective GRC programs look like. Integrating AI into GRC processes has already moved from a good-to-have experiment to being a critical prerequisite for managing modern risk and regulatory requirements at scale. Delaying adoption will only result in inefficient, fragmented risk intelligence and error-prone compliance efforts. Now is the time to define your organization's AI-first GRC vision and roadmap, invest in robust AI GRC solutions, and establish governance and oversight guardrails. Strategic AI integration can transform your GRC function into a powerful competitive advantage that strengthens resilience, builds trust, and supports sustainable growth.



About MetricStream

MetricStream simplifies Governance, Risk, and Compliance (GRC) with purpose-built AI-first Risk, Compliance, Audit, Cyber GRC, Third-party Risk, and Resilience products on a single low-code / no-code GRC cloud platform. Trusted by over 1 million GRC professionals across 35+ countries, our industry-specific products and AI agents help businesses successfully manage audits, avoid compliance violations and fines, reduce risk exposure, and strengthen resilience.

Earlier this year, MetricStream unveiled a new AI-first identity and product strategy that leverages agentic and generative AI to automatically capture data, perform assessments, gather evidence, generate insight summaries, and recommend action. This makes GRC simpler, faster, smarter, and outcome-driven. It also significantly reduces the burden on administrators and IT who manage systems by making it more seamless for them.



CONTACT US | REQUEST A DEMO

metricstream

© 2026 Copyright MetricStream. All Rights Reserved